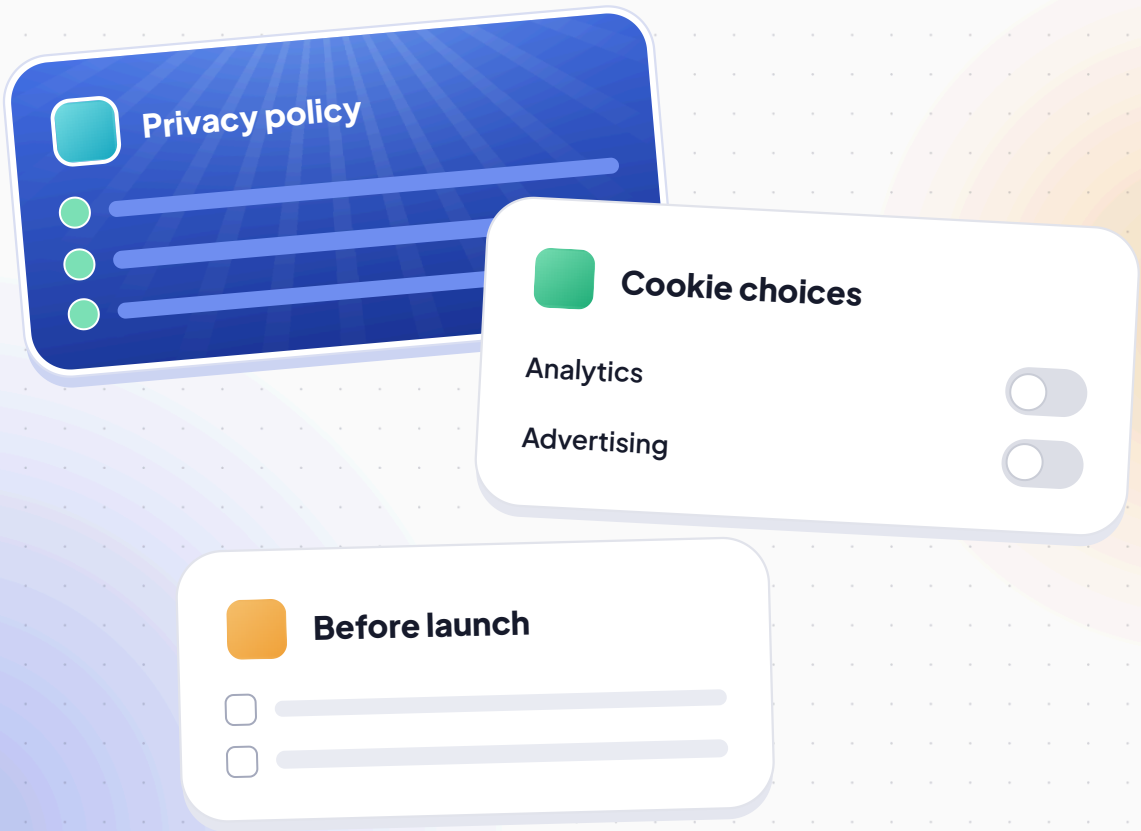
A working toolkit for founders and developers

The App *Launch* Checklist

35 legal, privacy, accessibility and trust checks to work through before you ship, each with plain-language context, applicability notes and step-by-step actions.



Disclaimer

Please read this page before relying on anything in this checklist.

General information only	This document provides general information about common legal, privacy, accessibility and consumer-protection topics that affect software products. It is not legal, regulatory, accessibility, security, tax or other professional advice, and it does not take account of any particular product, organisation, market or set of facts.
No professional relationship	Reading or using this document does not create a lawyer–client, consultant–client or any other professional relationship. It is not a substitute for advice from a qualified professional who knows your circumstances and the laws that apply to you.
Laws differ and change	Requirements differ between countries, regions, states and sectors, and depend on factors such as where your users are, what data you process, your business model, your size and your contractual role. Laws, regulations, regulatory guidance, court decisions and platform policies change frequently. The research behind this document reflects sources reviewed up to October 2026; later developments are not included, and some described rules may already have changed.
Not exhaustive	The checklist covers the topics in the short video it accompanies and is not a complete list of every obligation that may apply to an app. Regulated sectors, such as health, finance, education, gambling, employment and products for children, carry additional requirements that are outside its scope.
No guarantee of compliance or outcome	Completing every item does not guarantee compliance with any law, approval by any app store or platform, protection from complaints, investigations, claims or penalties, or any particular result. Ticking a box records that a step was considered; it does not demonstrate that the underlying product behaves correctly.
Accuracy and sources	Reasonable care was taken to summarise authoritative sources accurately, but summaries necessarily simplify. Always read the current official text of the laws, regulations and guidance listed in the references, and do not rely on this document where accuracy is critical.
Third-party references	References and links to external laws, regulators, standards, courts and companies are provided for convenience. Their inclusion does not imply endorsement, affiliation or approval, and their content and availability are outside the control of this document.
Examples and your responsibility	Examples, product names and figures in this document are fictional and illustrative. You remain responsible for decisions about your own product and for obtaining qualified advice before launch or before relying on any statement here. To the extent permitted by applicable law, no liability is accepted for loss arising from reliance on this document; nothing here excludes any liability that cannot lawfully be excluded.

How to use this checklist

The 35 sections are grouped into eight themes, so related topics sit together. The quote under each section title is the matching line from the video. Work through them with your product open in front of you.

1 Read the context

What it is explains the item and why it matters. *When it applies* explains the conditions, the jurisdictions involved and any qualification of the short instruction in the video.

2 Work the checklist

Each entry is one action. Entries are grouped into stages such as *Prepare*, *Implement* and *Verify*. Leave an entry unticked if it does not apply, and write down why.

3 Test the behaviour

Adding a policy page, banner or button is not the same as the product behaving that way. The *Verify* steps check that the control actually works.

4 Follow the sources

Reference codes such as R1 link to the references at the end. Check the current official text before relying on any summary.

Applicability labels

Good practice — Sensible for most apps whatever the law says.

Depends on jurisdiction — Legal requirements differ by country, region or state.

Depends on your app — Applies according to features, users, data, business model or contractual role.

Get qualified advice — Usually needs review by a qualified professional.

Abbreviations used

GDPR EU General Data Protection Regulation; **UK GDPR** its UK equivalent · **ePrivacy** EU Directive 2002/58/EC · **PECR** UK Privacy and Electronic Communications Regulations · **ICO** UK Information Commissioner's Office · **EDPB** European Data Protection Board · **CCPA** California Consumer Privacy Act (as amended by the CPRA) · **FTC** US Federal Trade Commission · **UCPD** EU Unfair Commercial Practices Directive · **DMCCA** UK Digital Markets, Competition and Consumers Act 2024 · **WCAG** Web Content Accessibility Guidelines · **SDK** software development kit · **DPA** data processing agreement · **SLA** service-level agreement.

Contents

All 35 topics from the video, grouped by theme. The quote under each title is the matching line from the video.

PART 1 Legal documents and disclosures

01 Privacy policy 5
"Add a privacy policy."

02 Terms of service 7
"Add terms of service."

03 Checkbox to accept the privacy policy and terms 8
"Add checkbox to accept the privacy policy and terms of service."

04 Terms acceptance records 9
"Record acceptance of the terms."

05 Refund policy 10
"Add a refund policy."

06 Business contact details 11
"Add business contact details."

PART 2 Consent, cookies and marketing

07 Cookie banner 12
"Add a cookie banner."

08 Trackers off until consent 13
"Block trackers until users consent."

09 Separate marketing consent 14
"Add separate marketing consent."

10 Unsubscribe option in marketing emails 15
"Add unsubscribe option to marketing emails."

PART 3 Handling personal data

11 Stop collecting unnecessary data 16
"Stop collecting unnecessary data."

12 Data retention limits 17
"Set data retention limits."

13 Data access and deletion requests 18
"Enable data access and deletion requests."

14 Parental consent for children's data 19
"Obtain parental consent before collecting children's data."

15 No unauthorized AI training on user data 20
"Prevent unauthorized AI training on user data."

PART 4 Vendors and third parties

16 Audit third-party SDKs, analytics and tracking 21
"Audit third-party SDKs, analytics, and tracking."

17 Data processing agreements 22
"Set up data processing agreements."

18 Subprocessor list 23
"Publish a subprocessor list."

PART 5 Accessibility

19 Colour contrast 24
"Fix colour contrast."

20 Alt text 25
"Add alt text."

21 Keyboard navigation 25
"Enable keyboard navigation."

PART 6 Fair design and pricing

22 Dark patterns 27
"Remove dark patterns."

23 Fake countdown timers 28
"Remove fake countdown timers."

24 Hidden fees 29
"Remove hidden fees."

25 Auto-renewal disclosure 30
"Disclose auto-renewals."

26 Easy subscription cancellation 31
"Make subscriptions easy to cancel."

PART 7 Honest claims and transparency

27 Unsupported claims 32
"Remove unsupported claims."

28 Fake reviews 33
"Remove fake reviews."

29 False SOC 2 claims 34
"Remove false SOC 2 claims."

30 Realistic uptime commitments 35
"State realistic uptime commitments."

31 Customer logos only with permission 36
"Don't use customer logos without permission."

32 AI-generated content labels 37
"Label AI-generated content."

PART 8 Intellectual property

33 Image, font and code licences 38
"Verify image, font, and code licences."

34 Open-source licence obligations 39
"Check open source license obligations."

35 DMCA agent registration 40
"Check DMCA registration requirements."

CLOSE Finishing up

✓ Final review before launch 41
"And most importantly, make no mistakes."

R References 42

PART 1

Legal documents and disclosures

01 Privacy policy
02 Terms of service
03 Checkbox to accept the privacy policy and terms
04 Terms acceptance records
05 Refund policy
06 Business contact details

01

"Add a privacy policy."

Privacy policy

Depends on jurisdiction
Depends on your app

WHAT IT IS

A privacy policy (also called a privacy notice) is the public explanation of what personal data your app collects, why, on what legal basis, who receives it, how long it is kept, and how people can exercise their rights. It must describe what the product actually does, so it has to be written from an inventory of real data flows, not copied from a template.

WHEN IT APPLIES

Required in many places once you collect personal data: the EU and UK GDPR set out the information you must give (Articles 13 and 14); California's CalOPPA requires a conspicuous policy for sites and apps collecting personal information from California residents; the CCPA adds content requirements for businesses that meet its thresholds. Apple and Google also require a privacy policy link for most apps. Which content items apply depends on where your users are and what you do with their data. The checklist below highlights key checks; it is not exhaustive and does not replace a complete, jurisdiction-specific assessment. The label before each action shows where it applies: Core items are expected under most privacy laws, region labels apply only where that law covers you, and Good practice items are recommended rather than legally required.

PREPARE

- [ ] Core Prepare and publish a comprehensive privacy policy tailored to the app's actual data practices and to every legal requirement that applies in your markets.
- [ ] Core List every category of personal data the app, website, backend, logs and third-party tools collect, including device identifiers and IP addresses.
- [ ] Core Record the purpose of each data category and, for EU or UK users, the lawful basis you rely on for that purpose.
- [ ] Core Identify every recipient of personal data, including hosting, analytics, email, payment, support and AI providers.
- [ ] Core Note any transfers of personal data outside the EU, UK or other source country and the safeguard used for each.

CORE DISCLOSURES

- [ ] Core State the identity and contact details of the business responsible for the data, plus a privacy contact or data protection officer where one is required.
- [ ] Core Describe the categories of personal data you collect, including data collected automatically, such as device identifiers and location.
- [ ] Core Explain in plain language the purposes for which each category of data is used.
- [ ] Core Name the recipients or categories of recipients, including service providers and any advertising or analytics partners.
- [ ] Core State a retention period or the criteria used to decide retention for each main data category.
- [ ] Core Explain each user right that applies (for example access, deletion, correction, portability, objection and opt-out of sale or sharing) and how to exercise it.
- [ ] Core Disclose any sale or sharing of personal information, targeted advertising, profiling or automated decision-making that the product actually performs.
- [ ] Good practice Describe in general terms how you protect personal data, without overstating your security.
- [ ] Core Add an effective date and keep previous versions so you can show what users were told at any point.
- [ ] Core Explain how users will be told about material changes to the policy.

IF THE EU OR UK GDPR APPLIES

- [ ] EU/UK State the lawful basis for each purpose, and the legitimate interests pursued where you rely on legitimate interests.
- [ ] EU/UK Explain the right to withdraw consent at any time where processing is based on consent.
- [ ] EU/UK Explain the right to complain to a data protection supervisory authority.
- [ ] EU/UK Describe international transfers, the safeguard used, and how users can obtain a copy or details of it.
- [ ] EU/UK State whether providing data is a statutory or contractual requirement and what happens if users do not provide it.
- [ ] EU/UK Disclose any automated decision-making with legal or similarly significant effects, with meaningful information about the logic involved.
- [ ] EU/UK Name your EU or UK representative where you are established outside the region and one is required.
- [ ] EU/UK Tell people the sources of personal data you obtain from third parties rather than from them directly.

IF US STATE LAWS APPLY

- [ ] California Include the content the CCPA requires, such as categories collected, their sources and purposes, and categories sold, shared or disclosed, if the CCPA applies to you.
- [ ] California Describe how users can submit requests, how you verify them, and how authorised agents can act for users.
- [ ] California Add 'Do Not Sell or Share' and 'Limit the Use of My Sensitive Personal Information' links where your practices trigger them.

- [ ] California Give a notice at collection at or before the point where personal information is collected.
- [ ] California Review and update the privacy policy at least once every 12 months while the CCPA applies.
- [ ] California Explain how the app responds to browser 'Do Not Track' signals, as CalOPPA requires.
- [ ] Other US states Check other state privacy laws whose thresholds you meet for extra items, such as how users can appeal a refused request.
- [ ] Children Provide the notices required by COPPA if the app is directed to children or knowingly collects their data (see section 14).

MAKE IT READABLE AND AVAILABLE

- [ ] Core Write the policy in clear, plain language with descriptive headings.
- [ ] Good practice Offer the policy in each language you market the app in.
- [ ] Core Link the policy from the website footer, the sign-up flow, the app settings screen and both app store listings.
- [ ] App stores Keep the App Store privacy details and the Google Play Data safety form consistent with the policy.

VERIFY

- [ ] Core Compare the policy line by line against the live data flows, SDK list and network traffic, and fix any mismatch in the product or the text.
- [ ] Core Confirm the policy loads without login, on mobile, and without being blocked by the cookie banner.
- [ ] Core Schedule a review whenever you add a vendor, feature, data category or new market.

Sources: R1 · R2 · R6 · R7 · R22 · R29

02

"Add terms of service."

Terms of service

Good practice Get qualified advice

WHAT IT IS

Terms of service (also called terms and conditions or terms of use) are the contract between you and your users. They set out what the service is, what users may and may not do, payment terms, intellectual-property ownership, liability limits, termination and how disputes are handled.

WHEN IT APPLIES

No single statute requires every app to have terms, but without them you have little contractual protection, and app stores, payment providers and some consumer laws expect certain terms to be disclosed. Consumer-protection laws in many countries make unfair or hidden terms unenforceable and prevent you from excluding statutory consumer rights, so terms aimed at consumers need jurisdiction-specific review.

DRAFT

- [ ] Describe the service, eligibility requirements (including any minimum age) and account responsibilities in plain language.
- [ ] Set out acceptable-use rules for user content and conduct, and the steps you take when they are broken.

- [ ] State who owns user content, what licence users grant you to operate the service, and who owns outputs if the app generates content.
- [ ] Explain pricing, billing, renewals, refunds and cancellation consistently with your refund and subscription pages.
- [ ] Include limitation-of-liability, disclaimer and dispute-resolution clauses only after checking they are enforceable against consumers in your markets.
- [ ] Explain how you will notify users of changes to the terms and when changes take effect.

IMPLEMENT

- [ ] Present the terms at sign-up and purchase with a clear acceptance step, and keep them reachable from the footer and settings.
- [ ] Version the terms and store which version each user accepted (see section 4).

VERIFY

- [ ] Check that the product, pricing pages and support practice actually match every promise made in the terms.
- [ ] Have a qualified lawyer review the terms for each market where you sell to consumers.

Sources: R11 · R18 · R37

03

"Add checkbox to accept the privacy policy and terms of service."

Checkbox to accept the privacy policy and terms

Good practice | Depends on jurisdiction | Get qualified advice

WHAT IT IS

A clear, deliberate acceptance step at sign-up helps show that users agreed to your terms. It should present the documents clearly and record the user's action.

WHEN IT APPLIES

This needs one qualification. Terms of service are a contract the user accepts. A privacy policy is a notice, and under the EU and UK GDPR it should usually be acknowledged rather than 'accepted', because consent is only one of several lawful bases. Consent for optional processing, such as marketing, must be separate, specific and not a condition of using the service where it is not needed. Pre-ticked boxes do not give valid GDPR consent (Planet49, Court of Justice of the EU). In the US, courts enforce online terms where notice is reasonably conspicuous and the user clearly shows agreement (for example Berman v. Freedom Financial Network, 9th Cir. 2022).

DESIGN

- [ ] Place the terms link and acceptance control next to the button that creates the account or completes the purchase.
- [ ] Use an unticked checkbox, or a clear 'By creating an account you agree to…' statement directly above the button, according to legal advice for your markets.
- [ ] Make the terms and privacy links visible, descriptive and openable before acceptance.

- [ ] Word the privacy policy reference as an acknowledgement, for example 'I have read the Privacy Policy', rather than consent to all processing.
- [ ] Keep optional consents, such as marketing, on separate controls that are not required to continue (see section 9).

IMPLEMENT

- [ ] Block account creation until required acceptance is given, and save the acceptance record (see section 4).
- [ ] Ask existing users to accept material changes to the terms through a similar clear step.

VERIFY

- [ ] Test the flow on small screens to confirm the links and checkbox are visible without scrolling past them.

Sources: R1 · R5 · R36 · R37

04

"Record acceptance of the terms."

Terms acceptance records

Good practice | Get qualified advice

WHAT IT IS

An acceptance record is the evidence that a particular user agreed to a particular version of your terms at a particular time, in a particular way. Without it, it is hard to rely on the terms in a dispute.

WHEN IT APPLIES

This is good practice almost everywhere. Under the GDPR, where processing relies on consent, the controller must be able to demonstrate consent (Article 7(1)), so the same record-keeping approach is useful there. US laws such as the E-SIGN Act recognise electronic records and signatures, subject to their conditions.

CAPTURE

- [ ] Store the user or account identifier, the document name and version, and the date and time with time zone.
- [ ] Store how acceptance happened, such as the sign-up checkbox, button text or screen.
- [ ] Keep an archived copy of every version of the terms and privacy notice exactly as shown.
- [ ] Record separately which optional consents, such as marketing, were given or refused.

PROTECT

- [ ] Make acceptance records append-only so later changes cannot overwrite history.
- [ ] Include acceptance records in your retention schedule and backup plan.

VERIFY

- [ ] Pick a test user and confirm you can show the exact terms version they accepted and when.

Sources: R1 · R24 · R37

05

"Add a refund policy."

Refund policy

Depends on jurisdiction | Depends on your app

WHAT IT IS

A refund policy tells customers whether, when and how they can get their money back, and how long it takes. It must be consistent with the statutory rights customers already have, which you usually cannot remove.

WHEN IT APPLIES

In the EU and UK, consumers usually have a 14-day right to withdraw from distance contracts, with specific rules for digital content and services. For example, the right can end once supply of digital content begins if the consumer gave prior express consent and acknowledged losing the right. EU traders must also provide an online withdrawal function for distance contracts concluded online from 19 June 2026 (Directive (EU) 2023/2673). In-app purchases through Apple or Google are refunded through the store's own processes. US rules vary by state and sector.

WRITE

- [ ] State which products and plans are refundable, the time limit and any conditions.
- [ ] Explain how to request a refund and how long processing takes.
- [ ] Explain how statutory rights, such as the EU and UK withdrawal right, work for your product, including any lawful exceptions.
- [ ] Tell app-store customers that refunds for in-app purchases are requested from Apple or Google.

IMPLEMENT

- [ ] Show the refund policy, or a link to it, before purchase and in the purchase confirmation.
- [ ] Collect express consent and the acknowledgement required to start digital supply within the withdrawal period, where you rely on that exception.
- [ ] Provide the EU online withdrawal function and confirm receipt of withdrawals where the EU rule applies to you.
- [ ] Train support staff and configure the payment system to apply the published policy consistently.

VERIFY

- [ ] Process a test refund end to end and confirm the timing and amount match the policy.

Sources: R18 · R19 · R29

06

"Add business contact details."

Business contact details

Depends on jurisdiction

WHAT IT IS

Users, regulators and partners need to know who runs the service and how to reach them. This usually means the legal business name, address, contact email and, where applicable, company registration and VAT numbers.

WHEN IT APPLIES

The EU e-Commerce Directive (Article 5) requires online service providers to give their name, geographic address, email and registration details. Germany requires an 'Impressum'. The Digital Services Act adds points of contact for intermediary services. The UK requires similar information under its e-commerce and company disclosure rules. CAN-SPAM requires a postal address in US commercial email, and app stores display developer or trader contact details, including for EU trader status.

PUBLISH

- [ ] Show the legal entity name exactly as registered, not only the brand name.
- [ ] Show a geographic address where the business can be reached, and a working contact email or form.
- [ ] Add company registration number, place of registration and VAT number where your jurisdiction requires them.
- [ ] Add any required regulator, licence or professional details for regulated activities.
- [ ] Make the contact details reachable from every page, for example through the footer, and from within the app.

ALIGN

- [ ] Make sure the same entity details appear in the terms, privacy policy, invoices, emails and app store listings.

VERIFY

- [ ] Send a test message through each published contact route and confirm someone receives and answers it.

Sources: R32 · R45 · R8 · R29

PART 2

Consent, cookies and marketing

07 Cookie banner
08 Trackers off until consent
09 Separate marketing consent
10 Unsubscribe option in marketing emails

07

"Add a cookie banner."

Cookie banner

Depends on jurisdiction
Depends on your app

WHAT IT IS

A cookie banner (consent management interface) asks users for permission before the site or app stores or reads non-essential information on their device, such as analytics cookies, advertising pixels, SDK identifiers and similar local storage. A banner is only the visible part; the important work is making sure trackers actually stay off until the user agrees (see section 8).

WHEN IT APPLIES

In the EU and UK, the ePrivacy rules (and the UK's PECR) require consent for storing or accessing information on a device unless it is strictly necessary for the service the user requested; the UK's Data (Use and Access) Act 2025 added some exemptions, such as certain statistical and functionality purposes, so check current ICO guidance. Most US state laws instead require notice and an opt-out of sale, sharing or targeted advertising, often including honouring browser opt-out signals. A banner that only says 'we use cookies' with an OK button is not valid consent in the EU or UK.

PREPARE

- [ ] Inventory every cookie, local-storage key, pixel and SDK identifier, with its provider, purpose and lifetime.
- [ ] Classify each item as strictly necessary or optional for each market you serve.

IMPLEMENT

- [ ] Offer 'Accept all' and 'Reject all' options with equal prominence on the first layer where EU or UK consent rules apply.
- [ ] Provide granular choices by purpose, such as analytics and advertising, with optional purposes switched off by default.
- [ ] Link to a cookie notice that names providers, purposes and retention periods.
- [ ] Provide a persistent way to change or withdraw choices later, such as a footer link or settings item.
- [ ] Store a record of each consent choice with the banner version and timestamp.
- [ ] Add a 'Do Not Sell or Share' or targeted-advertising opt-out where US state laws apply, and honour Global Privacy Control signals where required.

VERIFY

- [ ] Load the site in a clean browser, reject everything, and confirm in developer tools that no optional cookies or tracking requests fire.
- [ ] Confirm the site and app still work normally when optional cookies are rejected.

Sources: R3 · R4 · R5 · R38 · R6 · R33

08

"Block trackers until users consent."

Trackers off until consent

Depends on jurisdiction | Depends on your app

WHAT IT IS

Where consent is required, optional trackers must not load, set identifiers or send data until the user makes a choice that allows them. Essential functions, such as login, security and the shopping basket, should work regardless of that choice.

WHEN IT APPLIES

This 'prior consent' rule is specific to the EU and UK (ePrivacy Directive Article 5(3) and PECR), and covers storing or reading information on the device, not only cookies. Most US state laws do not require prior consent for typical analytics; they require notice and an opt-out from sale, sharing or targeted advertising, including honouring recognised opt-out signals such as Global Privacy Control in some states. Sensitive data, such as health data under Washington's My Health My Data Act, may need consent before collection.

IMPLEMENT

- [ ] Load optional scripts and SDKs only after the consent manager confirms the relevant purpose is allowed.
- [ ] Configure tag managers and SDKs so that their default state is off rather than on.
- [ ] Stop tracking and delete or stop using the related identifiers when a user withdraws consent.
- [ ] Detect and honour Global Privacy Control and similar opt-out signals where the law requires it.
- [ ] Keep core features independent of optional tracking so declining has no effect on access.

VERIFY

- [ ] In a fresh browser profile, confirm no optional tracking requests or cookies appear before a choice is made.
- [ ] Repeat the test after rejecting and after withdrawing consent.
- [ ] Repeat the test in the mobile app, checking advertising identifiers and SDK traffic before consent.

Sources: R3 · R4 · R38 · R6 · R33

09

"Add separate marketing consent."

Separate marketing consent

Depends on jurisdiction

WHAT IT IS

Agreeing to your terms should not automatically sign someone up for marketing. Marketing permission should be a distinct choice that users can give or refuse without affecting their access to the service.

WHEN IT APPLIES

In the EU and UK, electronic marketing generally needs prior consent under ePrivacy and PECR rules. This consent must be specific, unbundled and freely given under the GDPR, with a narrow 'soft opt-in' exception for similar products marketed to existing customers who were given a chance to refuse. Canada's Anti-Spam Legislation (CASL) also requires consent with limited exceptions. The US CAN-SPAM Act is opt-out based for email, but text messages and calls are subject to stricter consent rules such as the Telephone Consumer Protection Act (TCPA).

DESIGN

- [ ] Add a separate, unticked marketing opt-in that is not required to create an account or buy.
- [ ] Explain in plain words what marketing the user will receive and through which channels.
- [ ] Offer separate choices for different channels, such as email, SMS and push notifications, where the rules differ.
- [ ] Apply the soft opt-in only where its conditions are met, and give an opt-out at collection and in every message.

IMPLEMENT

- [ ] Store each marketing consent with its wording, source, date and time separately from terms acceptance.
- [ ] Sync consent and withdrawal status to every marketing tool before any message is sent.

VERIFY

- [ ] Create a test account without opting in and confirm it never receives marketing.

Sources: R3 · R4 · R5 · R8 · R1

10

"Add unsubscribe option to marketing emails."

Unsubscribe option in marketing emails

Depends on jurisdiction

WHAT IT IS

Every marketing message needs a clear, working way for the recipient to stop receiving it. This is separate from transactional and account messages, such as receipts and security alerts, which people normally cannot switch off.

WHEN IT APPLIES

In the US, the CAN-SPAM Act requires a clear opt-out in commercial email, processing within 10 business days, a mechanism that works for at least 30 days after sending, no fee or extra information beyond an email address and preferences, and a valid physical postal address. EU and UK rules (ePrivacy and PECR) require a simple way to refuse marketing in every message. Mailbox providers such as Google and Yahoo also require one-click unsubscribe headers for bulk senders.

IMPLEMENT

- [ ] Add a visible unsubscribe link to every marketing email, separate from any login or account settings.
- [ ] Make unsubscribing possible without logging in and without asking for anything beyond the email address and preferences.
- [ ] Add List-Unsubscribe and one-click unsubscribe headers through your email provider.
- [ ] Include your valid physical postal address in commercial email sent to US recipients.
- [ ] Offer a preference centre that lets people reduce or stop categories, while keeping a global 'unsubscribe from all marketing' option.

MAKE IT WORK

- [ ] Sync unsubscribes across every tool that sends marketing, including your email platform, CRM and in-app messaging.
- [ ] Keep a suppression list so unsubscribed addresses are never re-imported or re-added by a later sync.
- [ ] Separate marketing sends from transactional sends so required service emails keep working after an unsubscribe.

VERIFY

- [ ] Unsubscribe a test address and confirm no further marketing reaches it from any tool after processing.
- [ ] Check that unsubscribe links still work for emails sent at least 30 days ago.

Sources: R8 · R3 · R4

PART 3

Handling personal data

11 Stop collecting unnecessary data · 12 Data retention limits · 13 Data access and deletion requests · 14 Parental consent for children's data · 15 No unauthorized AI training on user data

11

"Stop collecting unnecessary data."

Stop collecting unnecessary data

Good practice · Depends on jurisdiction

WHAT IT IS

Data minimisation means collecting only the personal data you actually need for a defined purpose. Fields such as date of birth, phone number, address, contacts or precise location should only be collected when a feature truly needs them.

WHEN IT APPLIES

Data minimisation is a core principle of the EU and UK GDPR, and the CCPA requires collection to be reasonably necessary and proportionate to the disclosed purposes. Fewer data fields also reduce breach impact, request handling and app-store disclosure work.

REVIEW

- [ ] List every form field, permission request, SDK data point and log field, and write the purpose next to each.
- [ ] Mark each item as required, optional, or not needed.

REDUCE

- [ ] Remove fields and permissions that have no current purpose.
- [ ] Make genuinely optional fields clearly optional.
- [ ] Request device permissions, such as location, contacts or camera, only at the moment a feature needs them, with an explanation.
- [ ] Use less precise data where possible, such as approximate location or age range instead of full birth date.
- [ ] Stop logging sensitive values, such as passwords, tokens, payment data or health details, in application logs.
- [ ] Configure SDKs and analytics to disable data collection you do not use.

VERIFY

- [ ] Inspect real network traffic and log output to confirm removed data is no longer collected or sent.

Sources: R1 · R2 · R6 · R29

12

"Set data retention limits."

Data retention limits

Good practice | Depends on jurisdiction

WHAT IT IS

Retention limits define how long each type of data is kept and what happens when that time is up. Keeping data 'just in case' increases breach impact, storage cost and the scope of every access request.

WHEN IT APPLIES

The EU and UK GDPR require that personal data be kept no longer than necessary (storage limitation), and the CCPA requires businesses to disclose how long they keep each category of personal information. Other laws set minimum retention periods, for example for tax, accounting or employment records, so limits must balance both. Even where no law applies, a written schedule is sound good practice.

DECIDE

- [ ] Create a retention schedule listing each data category, its purpose, the retention period and the reason for that period.
- [ ] Check legal minimum periods for invoices, tax, accounting and dispute records in each country where you operate.
- [ ] Decide what happens at expiry for each category: deletion, anonymisation or archiving with restricted access.

IMPLEMENT

- [ ] Build automated deletion or anonymisation jobs for databases, file storage and search indexes.
- [ ] Apply retention settings in third-party tools such as analytics, logging, error tracking, support and email platforms.
- [ ] Include backups in the schedule and document how deleted data ages out of backup copies.
- [ ] Disclose retention periods or the criteria used in the privacy policy.

VERIFY

- [ ] Run a test record through its full lifecycle and confirm it is removed or anonymised on schedule everywhere it was copied.
- [ ] Review the schedule at least annually and whenever you add a new data category or vendor.

Sources: R1 · R2 · R6

13

"Enable data access and deletion requests."

Data access and deletion requests

Depends on jurisdiction | Depends on your app

WHAT IT IS

People may have rights to see the personal data you hold about them, receive a copy, correct it and have it deleted. You need a reliable way to receive these requests, verify the requester's identity and fulfil them across all your systems.

WHEN IT APPLIES

The EU and UK GDPR give rights of access, rectification, erasure and portability, with a response normally due within one month, extendable by up to two further months in some cases. The CCPA gives California residents rights to know, delete and correct, with responses generally due within 45 calendar days, extendable once by a further 45. Other US states have similar laws with their own thresholds. Apple and Google require apps that allow account creation to let users start account deletion from within the app, and Google Play also requires a web deletion option.

SET UP

- [ ] Publish at least one easy way to submit requests, such as an in-app form or a privacy email address, plus any methods your markets require.
- [ ] Define how you verify identity in proportion to the sensitivity of the data, without collecting excessive extra data.
- [ ] Map where each user's data lives, including databases, file storage, analytics, support, email and backups.

FULFIL

- [ ] Build an export that gives the user their data in a readable, commonly used format.
- [ ] Build in-app account deletion that removes or anonymises the account's data, not just deactivates it.
- [ ] Pass deletion requests to processors and vendors that hold the user's data.
- [ ] Document legal exceptions where you must keep some data, such as invoices, and tell the user what was kept and why.
- [ ] Log each request, its dates, verification and outcome so you can show deadlines were met.

VERIFY

- [ ] Run a full test request for a test account and confirm the export is complete and the deletion reaches every system.

Sources: R1 · R2 · R6 · R29

14

"Obtain parental consent before collecting children's data."

Parental consent for children's data

Depends on jurisdiction | Depends on your app | Get qualified advice

WHAT IT IS

If an app is directed to children, or knowingly collects children's personal data, many laws require verifiable consent from a parent or guardian before collection, along with stronger privacy defaults.

WHEN IT APPLIES

The age thresholds differ. In the US, the Children's Online Privacy Protection Act (COPPA) applies to services directed to children under 13 or with actual knowledge of collecting their data, and amended COPPA Rule requirements, including separate consent for most third-party disclosures, have applied since 22 April 2026. Under GDPR Article 8, parental consent is needed where an information society service relies on consent for children below 16, or a lower national age not below 13. The UK sets 13 and also applies the Age Appropriate Design Code. Several US states have additional rules for minors.

ASSESS

- [ ] Decide, with evidence, whether the app is directed to children or likely to be used by them in each market.
- [ ] Choose an age-assurance approach that is proportionate to the risk and does not collect more data than needed.

IMPLEMENT

- [ ] Collect only the minimum data needed to request parental consent until consent is obtained.
- [ ] Use a verifiable parental consent method recognised in the relevant jurisdiction.
- [ ] Give parents a direct notice explaining what is collected, how it is used and who receives it.
- [ ] Get separate parental consent for third-party disclosures, such as advertising, where the COPPA Rule requires it.
- [ ] Set high-privacy defaults for child users, such as disabling geolocation, profiling and public profiles.
- [ ] Give parents ways to review, delete and withdraw consent for their child's data.

VERIFY

- [ ] Test that no tracking, advertising or analytics data about the child leaves the app before consent.

Sources: R22 · R1 · R23

15

"Prevent unauthorized AI training on user data."

No unauthorized AI training on user data

Depends on jurisdiction | Depends on your app | Get qualified advice

WHAT IT IS

Using customer or user data to train, fine-tune or improve AI models is a separate purpose from providing the service. It needs a lawful basis, honest disclosure and, for business customers, contractual permission. It also includes data you send to AI vendors, who may use it for training unless their terms or settings prevent it.

WHEN IT APPLIES

Under the EU and UK GDPR, training is a purpose that needs its own lawful basis and must be compatible with what people were told; the European Data Protection Board (EDPB) addressed AI models in Opinion 28/2024. The FTC has warned that quietly changing terms or privacy policies to allow AI training on previously collected data may be unfair or deceptive. Data protection agreements with business customers usually prohibit processors from using customer data for their own purposes.

MAP

- [ ] List every place where user or customer data could reach model training, fine-tuning, evaluation or prompt logs.
- [ ] Check each AI vendor's terms and account settings for training, retention and human-review defaults.

CONTROL

- [ ] Disable vendor training on your data where their settings or contracts allow, and keep written confirmation.
- [ ] Exclude business customers' data from training unless their contract expressly permits it.
- [ ] Identify a lawful basis and give clear notice before any first-party training on personal data, with an opt-out or consent where required.
- [ ] Apply changes in data use only going forward unless users clearly agree to new uses of past data.
- [ ] Separate training datasets from production data, with documented sources and deletion handling.

VERIFY

- [ ] Confirm with vendors and internal teams that no unauthorised training pipeline exists, and record the check.

Sources: R1 · R28 · R30

PART 4

Vendors and third parties

16 Audit third-party SDKs, analytics and tracking
17 Data processing agreements
18 Subprocessor list

16

"Audit third-party SDKs, analytics, and tracking."

Audit third-party SDKs, analytics and tracking

Good practice | Depends on jurisdiction | Depends on your app

WHAT IT IS

Third-party software development kits (SDKs), analytics tools, advertising pixels, session-replay scripts and embedded widgets can send user data to other companies, sometimes more than you intended. You are responsible for what your app shares through them.

WHEN IT APPLIES

Undisclosed sharing has led to enforcement, including FTC action against health apps that shared sensitive data through advertising pixels. Rules vary: GDPR and ePrivacy rules in the EU and UK; US state privacy laws on 'sale' and 'sharing'; and specific laws for sensitive data, such as Washington's My Health My Data Act. Apple requires privacy manifests and accurate App Privacy details, and Google Play requires an accurate Data safety form, including data collected by SDKs.

INVENTORY

- [ ] List every SDK, script, pixel and embedded widget in the app and website, with its version and owner.
- [ ] Record what data each one collects and sends, where it goes, and why you use it.

INSPECT

- [ ] Capture real network traffic from the app and website with a proxy or browser developer tools.
- [ ] Check whether URLs, page titles, form fields or event names expose sensitive data such as health, financial or search information.
- [ ] Review vendor settings to disable features you do not need, such as advertising identifiers, session replay or automatic event capture.

ACT

- [ ] Remove SDKs you no longer use or cannot justify.
- [ ] Update the privacy policy, cookie notice, App Privacy details and Data safety form to match actual data flows.
- [ ] Put contracts in place with each vendor that receives personal data (see section 17).

VERIFY

- [ ] Re-run the traffic capture after each release that adds or updates SDKs.

Sources: R29 · R42 · R1 · R6 · R3

17

"Set up data processing agreements."

Data processing agreements

Depends on jurisdiction | Depends on your app | Get qualified advice

WHAT IT IS

A data processing agreement (DPA) is a contract between a business that decides how personal data is used (the controller) and a provider that processes it on the business's behalf (the processor), such as a hosting, email or analytics provider. It sets binding rules on how the provider may use and protect the data.

WHEN IT APPLIES

The EU and UK GDPR require a written contract with specific terms whenever a processor acts for a controller (Article 28(3)). The CCPA requires contracts with service providers and contractors that contain specified terms. International transfers may also need safeguards, such as the EU Standard Contractual Clauses or a valid adequacy decision, such as the EU-US Data Privacy Framework for certified companies. If you are the vendor to business customers, you will usually need to offer your own DPA.

MAP

- [ ] List each vendor that processes personal data for you and the role each plays, such as processor, service provider or independent controller.
- [ ] Identify which vendors transfer personal data to other countries and how those transfers are safeguarded.

CONTRACT

- [ ] Accept or sign each vendor's DPA, and confirm it covers the required terms for your markets.
- [ ] Keep signed or accepted copies, with dates and versions, in one place.
- [ ] Prepare your own DPA, and its transfer terms, if you process personal data for business customers.
- [ ] Check that vendor terms do not allow them to use your users' data for their own purposes, such as advertising or model training, unless you have agreed to that.

MAINTAIN

- [ ] Review DPAs when vendors change terms, add sub-processors or move data to new locations.

Sources: R1 · R2 · R6 · R30

18

"Publish a subprocessor list."

Subprocessor list

Good practice | Depends on jurisdiction | Depends on your app

WHAT IT IS

A subprocessor list names the third parties your service uses to process customers' personal data, with what each does and where. Publishing and maintaining it is the common way for software-as-a-service companies to keep business customers informed.

WHEN IT APPLIES

This needs qualification: no general law requires every app to publish a public list. However, under GDPR Article 28(2) and (4), a processor may only engage sub-processors with the controller's prior authorisation, and under a general authorisation it must inform the controller of intended changes so the controller can object. If you are a processor for business customers, a maintained list with change notifications is usually how you meet that obligation and your DPA terms. Consumer apps acting as controllers instead disclose recipients in their privacy policy.

PREPARE

- [ ] Decide whether you act as a processor for business customers, and check what your DPA promises about sub-processors.
- [ ] List each sub-processor's name, the service it provides, the data involved and its processing location.

PUBLISH

- [ ] Publish the list at a stable web address referenced in your DPA.
- [ ] Offer a way for customers to subscribe to change notifications.
- [ ] Give advance notice of new sub-processors for the period your DPA promises, and handle customer objections as the DPA describes.

MAINTAIN

- [ ] Update the list in the same release process that adds or removes a vendor.

Sources: R1 · R30

PART 5

Accessibility

19 Colour contrast · 20 Alt text · 21 Keyboard navigation

19

"Fix colour contrast."

Colour contrast

Good practice · Depends on jurisdiction

WHAT IT IS

Text and important interface elements must stand out enough from their background for people with low vision or colour-vision deficiencies, and for anyone using a phone in bright light. Contrast is measured as a ratio between foreground and background luminance.

WHEN IT APPLIES

The Web Content Accessibility Guidelines (WCAG) 2.2 at level AA require at least 4.5:1 for normal text and 3:1 for large text (success criterion 1.4.3), and 3:1 for meaningful interface components and graphics (1.4.11). WCAG is a technical standard rather than a law, but it is the benchmark used by many accessibility laws, including the EU's European Accessibility Act (applicable since 28 June 2025 to certain products and services such as e-commerce, with an exemption for microenterprises providing services), public-sector rules, and US Americans with Disabilities Act (ADA) case law and guidance. Which law applies depends on your sector, customers and size.

CHECK

- [ ] Measure the contrast of body text, placeholders, labels, links and disabled-looking text against their real backgrounds.
- [ ] Check text placed over images, gradients and video, using the lowest-contrast point behind the text.
- [ ] Check focus indicators, input borders, icons and chart elements against the 3:1 non-text contrast target.
- [ ] Check every state, including hover, pressed, error, success, disabled and dark mode.

FIX

- [ ] Adjust colour tokens in the design system rather than patching individual screens.
- [ ] Avoid using colour as the only way to convey meaning, and add text or icons to errors and statuses.

VERIFY

- [ ] Run an automated contrast checker on key flows and manually review anything it cannot measure, such as text over images.
- [ ] Recheck contrast after each brand or theme change.

Sources: R9 · R10 · R44

20

"Add alt text."

Alt text

Good practice | Depends on jurisdiction

WHAT IT IS

Alternative text (alt text) is a short text description of an image that screen readers announce and that appears if the image fails to load. Meaningful images need a description of their content or purpose; purely decorative images should be marked so screen readers skip them.

WHEN IT APPLIES

WCAG 2.2 success criterion 1.1.1 (Non-text Content) requires text alternatives for non-text content. The same laws and standards described in section 19 make this a legal expectation for many products, and it is good practice everywhere.

IMPLEMENT

- [ ] Add concise alt text describing the content or function of every meaningful image.
- [ ] Mark decorative images with an empty alt attribute, or hide them from assistive technology in native apps.
- [ ] Give image buttons and icon-only controls an accessible name that describes the action, such as 'Search'.
- [ ] Provide text alternatives for charts and infographics, such as a summary or data table.
- [ ] Require alt text, or a decorative flag, when users upload images to content your app publishes.

VERIFY

- [ ] Navigate key screens with a screen reader such as VoiceOver, TalkBack or NVDA and confirm images are announced sensibly.
- [ ] Run an automated checker to find images without alt text, then review the quality of existing alt text manually.

Sources: R9 · R10 · R44

21

"Enable keyboard navigation."

Keyboard navigation

Good practice | Depends on jurisdiction

WHAT IT IS

Everything a user can do with a mouse or touch should also be possible with a keyboard or equivalent assistive input, in a logical order, with a visible indicator showing where focus is.

WHEN IT APPLIES

WCAG 2.2 covers this in several success criteria, including 2.1.1 (Keyboard), 2.1.2 (No Keyboard Trap), 2.4.3 (Focus Order), 2.4.7 (Focus Visible) and 2.4.11 (Focus Not Obscured). The same legal context as section 19 applies.

IMPLEMENT

- [ ] Use native buttons, links and form controls, or add the correct roles and keyboard handling to custom components.
- [ ] Keep a visible focus indicator on every interactive element and never remove outlines without a replacement.

- [ ] Make the tab order follow the visual and logical reading order.
- [ ] Move focus into dialogs when they open, keep it there until they close, and return it to the triggering control afterwards.
- [ ] Add a 'skip to main content' link on pages with long navigation.
- [ ] Make sure sticky headers, cookie banners and chat widgets never hide the focused element.

VERIFY

- [ ] Complete sign-up, checkout, cancellation and settings flows using only the Tab, Shift+Tab, Enter, Space, Escape and arrow keys.
- [ ] Check that no component traps focus and that every focused element is clearly visible.

Sources: R9 · R10 · R44

PART 6

Fair design and pricing

22 Dark patterns · 23 Fake countdown timers · 24 Hidden fees · 25 Auto-renewal disclosure · 26 Easy subscription cancellation

22

"Remove dark patterns."

Dark patterns

Depends on jurisdiction

WHAT IT IS

Dark patterns (also called deceptive design) are interface choices that push people into decisions they would not otherwise make. Examples include confirmshaming ('No thanks, I hate saving money'), pre-ticked add-ons, hidden decline options, nagging prompts, disguised ads and making the privacy-friendly choice harder than the alternative.

WHEN IT APPLIES

Regulators treat many dark patterns as unlawful. Examples include the FTC under Section 5 of the FTC Act; the EU's UCPD and, for online platforms, Article 25 of the Digital Services Act; the UK DMCCA; and data protection authorities assessing whether consent was freely given. Exactly which practices are prohibited depends on the jurisdiction and context.

AUDIT

- [ ] Review sign-up, checkout, upgrade, cancellation, consent and notification-permission flows for pressure, trickery and asymmetry.
- [ ] List every pre-selected option, especially paid add-ons, marketing consent and data sharing.
- [ ] Compare the effort needed to accept against the effort needed to decline for each important choice.

FIX

- [ ] Give 'yes' and 'no' choices comparable size, placement and wording.
- [ ] Use neutral wording for decline options and remove guilt-based copy.
- [ ] Unselect add-ons and optional permissions by default, so users opt in deliberately.
- [ ] Show the full price and the key terms before the user commits.
- [ ] Label advertising and sponsored content clearly.

VERIFY

- [ ] Ask someone unfamiliar with the product to complete each key flow and check they understood what they agreed to.

Sources: R13 · R14 · R11 · R12 · R32 · R5

23

"Remove fake countdown timers."

Fake countdown timers

Depends on jurisdiction

WHAT IT IS

A fake countdown timer creates false urgency, for example an 'offer ends in 4:59' timer that resets on every visit, or a deadline that never actually ends. Timers are fine when they reflect a real deadline that you honour.

WHEN IT APPLIES

Falsely claiming that a product or price is available only for a very limited time is listed as an always-unfair practice in the EU Unfair Commercial Practices Directive (UCPD) and the UK Digital Markets, Competition and Consumers Act 2024 (DMCCA). The US Federal Trade Commission (FTC) has identified false scarcity and urgency as deceptive design under Section 5 of the FTC Act.

AUDIT

- [ ] Find every countdown, 'only X left', 'Y people viewing' and limited-time message in the app, website and emails.
- [ ] Confirm each one is driven by real data, such as a real end date or actual stock level.

FIX

- [ ] Remove timers that reset on reload, restart per visitor or continue after the stated deadline.
- [ ] Make sure the offer genuinely ends, or the price genuinely changes, when a real timer reaches zero.
- [ ] Base scarcity and popularity messages on live data, or remove them.

VERIFY

- [ ] Reload the page, use a private window and change devices to confirm the timer shows the same real deadline each time.
- [ ] Check after the deadline that the offer is no longer available at the old terms.

Sources: R11 · R12 · R13 · R14

24

"Remove hidden fees."

Hidden fees

Depends on jurisdiction

WHAT IT IS

Drip pricing means showing a lower headline price and adding mandatory fees, such as service, booking or processing fees, later in checkout. Customers should see the total price they must pay up front.

WHEN IT APPLIES

The FTC's Rule on Unfair or Deceptive Fees (16 CFR Part 464, in force since 12 May 2025) requires total-price display for live-event tickets and short-term lodging. Its scope is limited to those sectors, although deceptive fees elsewhere can still breach the FTC Act. California prohibits advertising a price that excludes most mandatory fees (Civil Code §1770(a)(29), since 1 July 2024). EU law requires the total price including taxes before purchase, and the UK DMCCA treats unavoidable fees left out of the headline price as misleading.

AUDIT

- [ ] List every fee that can be added during checkout and mark which are mandatory and which are optional.
- [ ] Compare the price on the listing, the product page, the basket and the final payment screen.

FIX

- [ ] Include all mandatory fees in the first price you show, or follow the specific total-price rules of each market.
- [ ] Show taxes, shipping and genuinely optional extras clearly, as permitted in each market, before payment.
- [ ] Show the full breakdown and total before the user enters payment details.
- [ ] Make optional extras opt-in rather than pre-selected.

VERIFY

- [ ] Complete a test purchase and confirm the amount charged matches the first total shown.

Sources: R31 · R11 · R12 · R18

25

"Disclose auto-renewals."

Auto-renewal disclosure

Depends on jurisdiction | Depends on your app

WHAT IT IS

If a plan renews automatically, users must clearly understand that it will renew, when, how much they will be charged, and how to cancel, before they agree to it.

WHEN IT APPLIES

In the US, ROSCA requires clear disclosure of material terms and express informed consent before charging for online negative-option offers. State laws, such as California's Automatic Renewal Law, add specific requirements for disclosures, consent, acknowledgements, renewal reminders and price-change notices. EU and UK information rules require the total price and the contract duration and renewal terms before purchase. Apple and Google have their own subscription disclosure rules.

DISCLOSE

- [ ] Show that the plan renews automatically, the renewal price, the billing frequency and the cancellation method next to the purchase button.
- [ ] Explain when a free trial converts to a paid plan and the amount that will be charged.
- [ ] Obtain express agreement to the automatic renewal terms before charging.

CONFIRM AND REMIND

- [ ] Send an acknowledgement after purchase that repeats the renewal terms and how to cancel.
- [ ] Send renewal reminders and price-change notices where state law or platform rules require them.

VERIFY

- [ ] Read the purchase screen as a new user and confirm the renewal terms are visible without opening other pages.
- [ ] Compare the in-app price and terms with the app store listing, website and confirmation email.

Sources: R20 · R21 · R18 · R19 · R29

26

"Make subscriptions easy to cancel."

Easy subscription cancellation

Depends on jurisdiction | Depends on your app

WHAT IT IS

Users should be able to cancel a subscription as easily as they signed up, without hidden steps, forced phone calls or repeated retention offers.

WHEN IT APPLIES

In the US, the FTC's 2024 'click-to-cancel' amendments to the Negative Option Rule were vacated by the Eighth Circuit in July 2025, but the Restore Online Shoppers' Confidence Act (ROSCA) still requires a simple way to stop recurring charges for online sales, and state laws apply, such as California's Automatic Renewal Law (online cancellation and related requirements, as amended from 1 July 2025). The EU's withdrawal-function rule and national laws, such as Germany's cancellation button, apply in Europe. The UK's subscription contracts regime under the DMCCA was reported in April 2026 as expected to start in spring 2027. App-store subscriptions are cancelled through the store.

DESIGN

- [ ] Let users who signed up online cancel online, in the same app or site, without calling or chatting.
- [ ] Place a clearly labelled cancellation option in account or billing settings.
- [ ] Limit retention offers to what the laws in your markets allow, and always let the user continue to cancel.
- [ ] For app-store subscriptions, link directly to the platform's subscription management page.

MAKE IT WORK

- [ ] Stop future charges when cancellation is confirmed, and state when access ends.
- [ ] Send a cancellation confirmation by email or in-app message.
- [ ] Sync cancellation status between your billing provider, app stores and your own database.

VERIFY

- [ ] Time the cancellation flow, count its steps, compare it with sign-up, and confirm no further charge is made.

Sources: R20 · R21 · R39 · R18 · R40 · R29

PART 7

Honest claims and transparency

27 Unsupported claims · 28 Fake reviews · 29 False SOC 2 claims · 30 Realistic uptime commitments · 31 Customer logos only with permission · 32 AI-generated content labels

27

"Remove unsupported claims."

Unsupported claims

Depends on jurisdiction · Get qualified advice

WHAT IT IS

Marketing claims about results, speed, savings, security, AI capability or comparisons with competitors must be true and supported by evidence before you make them. 'Guaranteed to double your revenue' needs proof; 'Track every sale in one place' only needs to describe a real feature.

WHEN IT APPLIES

The FTC requires a reasonable basis for objective claims before they are made (Policy Statement Regarding Advertising Substantiation). EU and UK consumer law prohibits misleading actions and omissions, and the UK advertising codes (CAP and BCAP) also require evidence. Health, financial, environmental and AI-capability claims attract particular scrutiny.

AUDIT

- [ ] List every claim in the website, app, app store listing, ads, emails and sales materials.
- [ ] Mark each claim as factual, comparative, a guarantee, a statistic or subjective puffery.

SUBSTANTIATE

- [ ] Keep dated evidence, such as test results, data or studies, for every objective claim before publishing it.
- [ ] Make sure statistics state their source, sample and date where that context affects their meaning.
- [ ] Remove or rewrite claims you cannot support.
- [ ] Qualify typical-results claims so they do not imply every user will get the best-case outcome.

MAINTAIN

- [ ] Re-check claims after product changes, and remove outdated ones.

Sources: R14 · R11 · R12

28

"Remove fake reviews."

Fake reviews

Depends on jurisdiction

WHAT IT IS

Reviews and testimonials must reflect genuine experiences of real customers. Problems include invented reviews, reviews written by staff or AI and presented as independent, incentivised reviews without disclosure, and suppressing negative reviews.

WHEN IT APPLIES

The FTC's Rule on the Use of Consumer Reviews and Testimonials (16 CFR Part 465, in force since October 2024) prohibits fake reviews and certain related practices. The UK DMCCA bans fake reviews and related practices (in force since 6 April 2025). The EU UCPD, as amended, prohibits fake reviews and requires traders to say whether and how they check that reviews are genuine. Removing fabricated reviews does not mean removing genuine ones.

AUDIT

- [ ] Trace every review, rating and testimonial shown in the app, website, ads and store listings back to a real customer and source.
- [ ] Identify reviews written by staff, friends, AI tools or paid reviewers, and any that were incentivised.

FIX

- [ ] Remove reviews you cannot trace to a genuine customer experience.
- [ ] Disclose any incentives or relationships connected to a review clearly and close to the review.
- [ ] Show negative and positive genuine reviews by the same rules, without selectively suppressing criticism.
- [ ] Describe how you collect and check reviews where EU or UK rules require that information.

MAINTAIN

- [ ] Do not buy reviews or offer rewards that depend on the review being positive.

Sources: R16 · R12 · R11 · R15

29

“Remove false SOC 2 claims.”

False SOC 2 claims

Good practice | Depends on jurisdiction

WHAT IT IS

SOC 2 (System and Organization Controls 2) is a framework from the American Institute of Certified Public Accountants (AICPA). A SOC 2 report is an independent attestation by a licensed CPA firm on a service organisation's controls against the Trust Services Criteria, either at a point in time (Type 1) or over a period (Type 2). It is not a certification, a government licence or a universal legal requirement.

WHEN IT APPLIES

Claims such as 'SOC 2 certified' or 'SOC 2 compliant' are misleading if no report exists, if the report is out of date, or if it covers a different system. False security or compliance claims can be deceptive under consumer-protection law, such as the FTC Act, and can breach customer contracts. Many companies have no SOC 2 report, which is fine; the problem is claiming one you do not have.

AUDIT

- [ ] Search the website, app, sales decks, security questionnaires and trust pages for SOC 2, ISO, HIPAA, GDPR and similar compliance wording.
- [ ] Check that each claim matches a current report or certificate, its scope, its type and its period.

FIX

- [ ] Remove SOC 2 claims you cannot support with a current report from an independent CPA firm.
- [ ] Describe status precisely, such as 'SOC 2 Type 2 report available under NDA for the period…', rather than 'certified'.
- [ ] Avoid implying that a cloud provider's SOC 2 report covers your own application.
- [ ] Describe the security practices you actually follow, without labels you have not earned.

MAINTAIN

- [ ] Review security and compliance claims whenever a report expires or its scope changes.

Sources: R26 · R14

30

"State realistic uptime commitments."

Realistic uptime commitments

Good practice | Get qualified advice

WHAT IT IS

An uptime commitment states how available the service will be, often as a percentage over a period, sometimes with service credits in a service-level agreement (SLA). '100% uptime, guaranteed' is rarely achievable and can create contractual or advertising problems.

WHEN IT APPLIES

No general law sets uptime levels for apps. Uptime promises in contracts are binding, and untrue availability claims in marketing can be misleading under consumer and advertising law. Commitments should match your real architecture and your providers' own SLAs.

SET THE COMMITMENT

- [ ] Base any uptime target on measured historical availability and your hosting providers' SLAs.
- [ ] Define how uptime is measured, over what period, and which components are covered.
- [ ] List exclusions, such as scheduled maintenance announced in advance, customer-caused issues and force majeure.
- [ ] Define remedies, such as service credits, and how customers claim them, if you offer an SLA.

COMMUNICATE

- [ ] Remove absolute claims such as '100% uptime' or 'never goes down' from marketing.
- [ ] Publish a status page that reports incidents and maintenance honestly.

VERIFY

- [ ] Monitor availability independently and compare actual results with your stated commitment each month.

Sources: R14 · R11

31

"Don't use customer logos without permission."

Customer logos only with permission

Good practice | Depends on jurisdiction | Get qualified advice

WHAT IT IS

Showing a company's logo on your site ('Trusted by…') implies a relationship and often an endorsement. Logos are usually trademarks, and customer contracts frequently restrict publicity.

WHEN IT APPLIES

Using a logo without permission can raise trademark and false-endorsement issues, such as under the US Lanham Act, and can breach a confidentiality or publicity clause in your contract. Implying an endorsement that does not exist can also be deceptive advertising under consumer-protection laws such as the FTC Act and its Endorsement Guides. The exact rules vary by country and by contract.

CHECK

- [ ] List every logo, company name and case study shown on your website, app, sales deck and app store listing.
- [ ] Check each customer contract for publicity, confidentiality or logo-use clauses.

ACT

- [ ] Obtain written permission for each logo, including any brand-guideline requirements and approved wording.
- [ ] Remove logos of companies that are not current customers or that have not given permission.
- [ ] Avoid wording that implies endorsement, partnership or certification when the relationship is only that the company is a customer.
- [ ] Keep permissions on file with the date and scope of approval.

MAINTAIN

- [ ] Remove a customer's logo promptly when the relationship ends or the customer withdraws permission.

Sources: R35 · R15 · R14

32

"Label AI-generated content."

AI-generated content labels

Depends on jurisdiction | Depends on your app

WHAT IT IS

Labelling tells people when content was created or materially altered by artificial intelligence (AI), or when they are interacting with an AI system rather than a person. This helps users judge content and avoids misleading them.

WHEN IT APPLIES

Under Article 50 of the EU AI Act, transparency obligations began to apply on 2 August 2026. Providers must make sure people know when they are interacting with an AI system, and must mark synthetic audio, image, video and text in a machine-readable way (reports indicate systems already on the EU market before that date have until 2 December 2026 for this marking). Deployers must disclose deepfakes and AI-generated text published to inform the public on matters of public interest, subject to exceptions. Outside the EU, labelling is mainly good practice, required by platform policies, or needed to avoid deceptive claims. Check the latest European Commission guidance, because the detail is still being clarified.

MAP

- [ ] List every place where the app generates or edits text, images, audio or video, and every chatbot or AI agent users interact with.
- [ ] Decide whether your role for each feature is provider, deployer or neither under the EU AI Act, with advice if unclear.

IMPLEMENT

- [ ] Tell users clearly when they are talking to an AI system rather than a person.
- [ ] Add a visible label to AI-generated or materially AI-edited images, video and audio where users could be misled.
- [ ] Apply machine-readable marking, such as metadata or content credentials, where your role and market require it.
- [ ] Keep labels attached when content is downloaded, shared or embedded, where technically feasible.
- [ ] Follow app store and social platform AI-disclosure rules for content you publish there.

VERIFY

- [ ] Check that labels appear on every surface where AI content is shown, including exports and notifications.

Sources: R17 · R14

PART 8

Intellectual property

33 Image, font and code licences | 34 Open-source licence obligations | 35 DMCA agent registration

33

"Verify image, font, and code licences."

Image, font and code licences

Good practice | Get qualified advice

WHAT IT IS

Every image, illustration, icon, font, sound, video and code snippet in your product is covered by copyright and a licence. 'Found online' is not a licence, and many licences restrict how and where the asset may be used.

WHEN IT APPLIES

This applies to every app. Typical problems include stock images licensed for editorial use only, desktop font licences used as web or app-embedded fonts, Creative Commons non-commercial assets in a commercial product, and code copied from forums without attribution. For AI-generated assets, check the tool's terms; the US Copyright Office's position is that material without sufficient human authorship is not protected by copyright, which may limit your own rights in it. Open-source software licences are covered in section 34.

INVENTORY

- [ ] List every image, icon set, illustration, font, audio file, video and copied code snippet used in the product and marketing.
- [ ] Record the source, licence type, licence holder and proof of licence for each asset.

CHECK

- [ ] Confirm image and video licences cover commercial use in your specific media, such as an app, ads or merchandise.
- [ ] Confirm font licences cover the way you use them, such as web embedding, app embedding, logo use or PDF embedding.
- [ ] Comply with attribution and share-alike terms for Creative Commons and similar licences, and avoid non-commercial licences in commercial products.
- [ ] Check the terms of any AI tool used to generate assets for ownership, permitted use and restrictions.

FIX

- [ ] Replace any asset whose licence cannot be confirmed or does not cover your use.
- [ ] Add required attributions to an in-app or website credits page.

Sources: R25 · R34

34

"Check open source license obligations."

Open-source licence obligations

Good practice | Get qualified advice

WHAT IT IS

Open-source licences give you permission to use code on conditions. Common conditions include keeping copyright notices, including the licence text, stating changes, and in some cases making source code available.

WHEN IT APPLIES

Permissive licences, such as MIT, BSD and Apache-2.0, mainly require notices and attribution, and Apache-2.0 also has NOTICE-file and patent provisions. Copyleft licences, such as GPL and LGPL, can require you to provide source code when you distribute the software, and the AGPL extends this to software users interact with over a network. Obligations depend on how you use, modify and distribute each component, so non-trivial cases deserve specialist review.

INVENTORY

- [ ] Generate a software bill of materials (SBOM) that lists every direct and transitive dependency with its version and licence.
- [ ] Flag components under copyleft or unclear licences for review before release.

COMPLY

- [ ] Include required copyright notices and licence texts in the app, such as an 'Open-source licences' screen.
- [ ] Include Apache-2.0 NOTICE file contents where a component provides one.
- [ ] Decide, with advice, how copyleft obligations apply to your distribution model, and provide source code or written offers where required.
- [ ] Keep the licence and notice requirements of copied snippets and vendored code.

MAINTAIN

- [ ] Add automated licence checks to the build pipeline so new dependencies are reviewed before they ship.

Sources: R25

35

"Check DMCA registration requirements."

DMCA agent registration

Depends on jurisdiction | Depends on your app

WHAT IT IS

The US Digital Millennium Copyright Act (DMCA) gives online service providers a 'safe harbor' from copyright liability for material uploaded by users, if they meet certain conditions. One condition for hosting providers is designating an agent to receive copyright notices and registering that agent with the US Copyright Office.

WHEN IT APPLIES

This matters if your app hosts or stores user-uploaded content and you want US safe-harbor protection under 17 U.S.C. §512(c). You must publish the agent's contact details on your service and register the agent in the Copyright Office's online directory. Registrations expire after three years unless renewed (37 CFR §201.38). Other conditions also apply, including a repeat-infringer policy and expeditious takedown. Other countries have their own notice-and-action regimes, such as the EU Digital Services Act. If users cannot upload or share content, this item may not apply.

DECIDE

- [ ] Confirm whether the app hosts, stores or displays content uploaded by users.
- [ ] Get advice on which safe harbor and notice regimes apply in your markets.

IMPLEMENT

- [ ] Register a designated agent in the US Copyright Office DMCA Designated Agent Directory and pay the fee.
- [ ] Publish the agent's name, address, phone number and email on your website and in the terms.
- [ ] Publish a copyright policy explaining how to send notices and counter-notices.
- [ ] Adopt and enforce a policy for terminating repeat infringers in appropriate circumstances.
- [ ] Build an internal workflow to remove or disable access to reported material quickly and notify the uploader.

MAINTAIN

- [ ] Set a calendar reminder to renew the agent registration before its three-year expiry and whenever details change.

Sources: R27 · R32

"And most importantly, make no mistakes."

Final review before launch

No checklist can make a product mistake-free or guarantee compliance. What it can do is make sure you have asked the right questions, tested real behaviour and brought in qualified people where the answer depends on your circumstances.

REVIEW

- [ ] Have a qualified lawyer review your privacy policy, terms, refund and subscription flows, and marketing claims for each market where you will launch.
- [ ] Ask an accessibility specialist or disabled users to test key flows with assistive technologies, in addition to automated tools.
- [ ] Confirm you have identified which laws apply, based on where your users are, what data you process and your role in each data flow.

RE-TEST

- [ ] Repeat the verification steps in this checklist on the final release build, not only on a development version.
- [ ] Confirm that public documents, app store listings and the live product describe the same behaviour.

KEEP IT CURRENT

- [ ] Assign an owner for each section and a date to review it again.
- [ ] Re-run the relevant sections whenever you add a feature, vendor, data category, pricing model or new market.

References

Official legislation, regulator guidance, standards and court decisions consulted.
Read the current official text before relying on any summary in this document.

R1 **Regulation (EU) 2016/679, General Data Protection Regulation (GDPR), including Articles 5, 6, 7, 8, 12–17, 20, 25, 28**
EUR-Lex · eur-lex.europa.eu/eli/reg/2016/679/oj
Used in sections 1, 3, 4, 9, 11, 12, 13, 14, 15, 16, 17, 18

R2 **UK GDPR and Data Protection Act 2018, with ICO guidance and the Data (Use and Access) Act 2025 overview**
Information Commissioner's Office (ICO) · ico.org.uk/for-organisations
Used in sections 1, 11, 12, 13, 17

R3 **Directive 2002/58/EC (ePrivacy Directive), including Article 5(3) on device storage and access and Article 13 on electronic marketing**
EUR-Lex · eur-lex.europa.eu/eli/dir/2002/58/oj
Used in sections 7, 8, 9, 10, 16

R4 **Privacy and Electronic Communications Regulations 2003 (PECR) and ICO guidance on storage and access technologies and direct marketing**
legislation.gov.uk; ICO · www.legislation.gov.uk/uksi/2003/2426
Used in sections 7, 8, 9, 10

R5 **Guidelines 05/2020 on consent under Regulation 2016/679**
European Data Protection Board (EDPB) · www.edpb.europa.eu/our-work-tools/our-documents/guidelines/guidelines-052020-consent-under-regulation-2016679_en
Used in sections 3, 7, 9, 22

R6 **California Consumer Privacy Act as amended by the CPRA (Cal. Civ. Code §1798.100 et seq.) and CCPA Regulations (Cal. Code Regs. tit. 11, §7000 et seq.)**
California Privacy Protection Agency · cppa.ca.gov/regulations
Used in sections 1, 7, 8, 11, 12, 13, 16, 17

R7 **California Online Privacy Protection Act (CalOPPA), Cal. Bus. & Prof. Code §§22575–22579**
California Legislative Information · leginfo.legislature.ca.gov
Used in sections 1

R8 **CAN-SPAM Act (15 U.S.C. §7701 et seq.), 16 CFR Part 316 and the CAN-SPAM Act Compliance Guide for Business**
U.S. Federal Trade Commission (FTC) · www.ftc.gov/business-guidance/resources/can-spam-act-compliance-guide-business
Used in sections 6, 9, 10

R9 **Web Content Accessibility Guidelines (WCAG) 2.2, W3C Recommendation**
World Wide Web Consortium (W3C) · www.w3.org/TR/WCAG22
Used in sections 19, 20, 21

R10 **Directive (EU) 2019/882, European Accessibility Act (applicable from 28 June 2025), and harmonised standard EN 301 549**
EUR-Lex · eur-lex.europa.eu/eli/dir/2019/882/oj
Used in sections 19, 20, 21

R11 **Directive 2005/29/EC on Unfair Commercial Practices, as amended by Directive (EU) 2019/2161, including Annex I**
EUR-Lex · eur-lex.europa.eu/eli/dir/2005/29/oj
Used in sections 2, 22, 23, 24, 27, 28, 30

R12 **Digital Markets, Competition and Consumers Act 2024 (Part 4 and Schedule 20) and CMA guidance on unfair commercial practices**
legislation.gov.uk; Competition and Markets Authority · www.legislation.gov.uk/ukpga/2024/13
Used in sections 22, 23, 24, 27, 28

R13 **Bringing Dark Patterns to Light, FTC staff report (September 2022)**
U.S. Federal Trade Commission · www.ftc.gov/reports/bringing-dark-patterns-light
Used in sections 22, 23

R14 **FTC Act §5 (15 U.S.C. §45) and FTC Policy Statement Regarding Advertising Substantiation**
U.S. Federal Trade Commission · www.ftc.gov/legal-library/browse/ftc-policy-statement-regarding-advertising-substantiation
Used in sections 22, 23, 27, 29, 30, 31, 32

R15 **Guides Concerning the Use of Endorsements and Testimonials in Advertising, 16 CFR Part 255**
Electronic Code of Federal Regulations · www.ecfr.gov/current/title-16/chapter-I/subchapter-B/part-255
Used in sections 28, 31

R16 **Trade Regulation Rule on the Use of Consumer Reviews and Testimonials, 16 CFR Part 465**
Electronic Code of Federal Regulations · www.ecfr.gov/current/title-16/chapter-I/subchapter-D/part-465
Used in sections 28

R17 **Regulation (EU) 2024/1689 (AI Act), Article 50, and the Commission's FAQ on Article 50 transparency obligations**
EUR-Lex; European Commission · digital-strategy.ec.europa.eu/en/faqs/transparency-obligations-under-article-50-ai-act
Used in sections 32

R18 **Directive 2011/83/EU on Consumer Rights and Directive (EU) 2023/2673 (online withdrawal function, applicable from 19 June 2026)**
EUR-Lex · eur-lex.europa.eu/eli/dir/2011/83/oj
Used in sections 2, 5, 24, 25, 26

R19 **Consumer Contracts (Information, Cancellation and Additional Charges) Regulations 2013**
legislation.gov.uk · www.legislation.gov.uk/uksi/2013/3134
Used in sections 5, 25

R20 **Restore Online Shoppers' Confidence Act (ROSCA), 15 U.S.C. §§8401–8405**
Office of the Law Revision Counsel · uscode.house.gov/view.xhtml?path=/prelim@title15/chapter110
Used in sections 25, 26

R21 **California Automatic Renewal Law, Cal. Bus. & Prof. Code §§17600–17606, as amended by AB 2863 (effective 1 July 2025)**
California Legislative Information · leginfo.legislature.ca.gov
Used in sections 25, 26

R22 **Children's Online Privacy Protection Rule, 16 CFR Part 312 (amended rule; compliance date 22 April 2026)**
U.S. Federal Trade Commission · www.ftc.gov/legal-library/browse/rules/childrens-online-privacy-protection-rule-coppa
Used in sections 1, 14

R23 **Age appropriate design: a code of practice for online services (Children's code)**
Information Commissioner's Office (ICO) · ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/childrens-information/childrens-code-guidance-and-resources
Used in sections 14

R24 **Electronic Signatures in Global and National Commerce Act (E-SIGN), 15 U.S.C. §7001 et seq.**
Office of the Law Revision Counsel · uscode.house.gov/view.xhtml?path=/prelim@title15/chapter96
Used in sections 4

R25 **Open Source Initiative licence list; SPDX License List; GNU licences FAQ; Apache License 2.0**
opensource.org; spdx.org; gnu.org; apache.org · opensource.org/licenses
Used in sections 33, 34

R26 **System and Organization Controls: SOC suite of services, including SOC 2 and the Trust Services Criteria**
AICPA & CIMA · www.aicpa-cima.com/resources/landing/system-and-organization-controls-soc-suite-of-services
Used in sections 29

R27 **17 U.S.C. §512 and 37 CFR §201.38; DMCA Designated Agent Directory**
U.S. Copyright Office · www.copyright.gov/dmca-directory
Used in sections 35

R28 **AI (and other) Companies: Quietly Changing Your Terms of Service Could Be Unfair or Deceptive (FTC Technology Blog, February 2024); EDPB Opinion 28/2024 on AI models**
U.S. Federal Trade Commission; European Data Protection Board · www.edpb.europa.eu
Used in sections 15

R29 **App Review Guidelines (including 5.1.1 data collection and account deletion; 3.1.2 subscriptions) and privacy manifest documentation; Google Play Developer Policy (User Data, account deletion, Data safety, subscriptions)**
Apple Developer; Google Play Console Help · developer.apple.com/app-store/review/guidelines
Used in sections 1, 5, 6, 11, 13, 16, 25, 26

R30 **Commission Implementing Decision (EU) 2021/914 on Standard Contractual Clauses for international transfers**
EUR-Lex · eur-lex.europa.eu/eli/dec_impl/2021/914/oj
Used in sections 15, 17, 18

R31 **Rule on Unfair or Deceptive Fees, 16 CFR Part 464 (effective 12 May 2025); Cal. Civ. Code §1770(a)(29) (SB 478)**
Electronic Code of Federal Regulations; California Legislative Information · www.ecfr.gov/current/title-16/chapter-I/subchapter-D/part-464
Used in sections 24

R32 **Directive 2000/31/EC (e-Commerce Directive), Article 5; Regulation (EU) 2022/2065 (Digital Services Act); UK Electronic Commerce (EC Directive) Regulations 2002; Companies (Trading Disclosures) Regulations 2008**
EUR-Lex; legislation.gov.uk · eur-lex.europa.eu/eli/reg/2022/2065/oj
Used in sections 6, 22, 35

R33 **Global Privacy Control specification; CCPA Regulations §7025 on opt-out preference signals**
globalprivacycontrol.org; California Privacy Protection Agency · globalprivacycontrol.org
Used in sections 7, 8

R34 **Copyright and Artificial Intelligence (registration guidance and reports)**
U.S. Copyright Office · www.copyright.gov/ai
Used in sections 33

R35 **Lanham Act §43(a), 15 U.S.C. §1125(a) (false designation and false endorsement)**
Office of the Law Revision Counsel · uscode.house.gov
Used in sections 31

R36 **Case C-673/17, Planet49 GmbH, Judgment of the Court of Justice of the EU, 1 October 2019**
EUR-Lex · eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:62017CJ0673
Used in sections 3

R37 **Berman v. Freedom Financial Network, LLC, 30 F.4th 849 (9th Cir. 2022), on online contract formation**
U.S. Court of Appeals for the Ninth Circuit · www.ca9.uscourts.gov/opinions
Used in sections 2, 3, 4

R38 **Cookies and other trackers: guidance and recommendations**
Commission nationale de l'informatique et des libertés (CNIL) · www.cnil.fr/en/cookies-and-other-trackers
Used in sections 7, 8

R39 **Custom Communications, Inc. v. FTC (8th Cir., 8 July 2025), vacating the amended Negative Option Rule**
U.S. Court of Appeals for the Eighth Circuit · www.ca8.uscourts.gov
Used in sections 26

R40 **DMCCA 2024, Part 4 Chapter 2 (subscription contracts); commencement reported in April 2026 as expected in spring 2027**
legislation.gov.uk; GOV.UK · www.legislation.gov.uk/ukpga/2024/13/part/4/chapter/2
Used in sections 26

R42 **FTC enforcement action against GoodRx (2023) concerning health data shared through advertising tools; Washington My Health My Data Act (RCW 19.373)**
U.S. Federal Trade Commission; Washington State Legislature · www.ftc.gov/legal-library/browse/cases-proceedings/2023090-goodrx-holdings-inc
Used in sections 16

R44 **Guidance on Web Accessibility and the ADA**
U.S. Department of Justice · www.ada.gov/resources/web-guidance
Used in sections 19, 20, 21

R45 **Digitale-Dienste-Gesetz (DDG) §5, general information obligations (Impressum)**
Federal Ministry of Justice (Germany) · www.gesetze-im-internet.de/ddg/__5.html
Used in sections 6